

CONFIDENTIAL

Zero Trust Security Assessment

Microsoft Entra ID & Endpoint — Technical Findings Report
Prepared for **Contoso Ltd**

Engagement	ENG-2026-042
Tenant ID	204d355e-3092-40a5-b516-b8c31be6717b
Assessment date	13 June 2026, 07:31 UTC
Toolkit	Get-EntraZTAssess — Entra ID Security & Endpoint Zero Trust Assessment
Classification	Confidential — client distribution
Checks evaluated	92 controls across 14 Zero Trust domains

This report is based on read-only Microsoft Graph collection. No tenant configuration was modified during the assessment.

Contents

1. Executive Summary

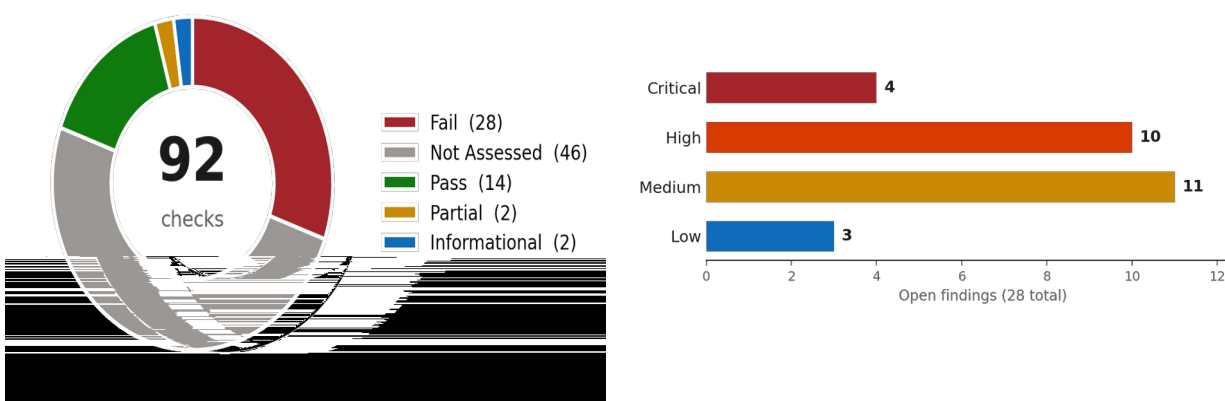
This assessment evaluated the identity and endpoint Zero Trust posture of the Contoso Ltd Microsoft Entra ID tenant against 92 declarative controls spanning fourteen security domains. The toolkit collected configuration read-only through Microsoft Graph and scored each control as Pass, Fail, Partial, Informational or Not Assessed.

The headline picture is a tenant with sound foundations in a few areas — application consent governance, credential hygiene and passwordless enablement — but with the core Zero Trust enforcement layer almost entirely absent. There is no enforced tenant-wide multi-factor authentication, no administrator MFA, no block on legacy authentication, and no device- or risk-based access control in enforced mode. Several of these controls exist but remain stuck in report-only, creating a false sense of coverage. In combination these gaps leave both the general user population and highly privileged administrators directly exposed to the most common identity attacks: password spray, phishing and illicit consent.

Of the 92 controls, 46 returned actionable findings. The remaining 46 could not be assessed — overwhelmingly because the tenant has no Intune licence and managed-device permissions were not granted, and because it is a cloud-only tenant with no on-premises synchronisation to evaluate. These are summarised in Section 7 and listed in the Appendix.

92 CONTROLS	28 FAIL	2 PARTIAL	14 PASS	2 INFO	46 NOT ASSESSED
-----------------------	-------------------	---------------------	-------------------	------------------	---------------------------

Posture at a glance



Outcome of all 92 controls (left) and the severity distribution of the 28 open Fail findings (right). Four Critical and ten High findings dominate the remediation agenda.

What demands attention first

- **Administrators are under-protected.** Three of ten privileged accounts cannot perform MFA at all, and no enforced policy requires MFA for administrator roles. A single compromised admin credential is a direct path to full tenant takeover (ID-002, CA-002).

- **There is no enforced baseline MFA.** No enabled policy requires MFA for all users across all apps, and overall MFA registration sits at 31.8% against a 95% target. The controls largely exist but remain in report-only (CA-001, ID-001, CA-009).
- **Privilege is permanent, not just-in-time.** Eighteen standing privileged assignments, zero PIM-eligible, and six Global Administrators exceed the recommended ceiling. Standing privilege is exploitable around the clock (PA-001, PA-002).
- **Legacy authentication is open.** No policy blocks legacy protocols, which cannot enforce MFA and are the classic password-spray vector (CA-003, ID-003).
- **Detection exists but does not act.** Identity Protection risk signals are collected but enforced by no policy, a risky user has gone unremediated past SLA, and log retention beyond 30 days is unconfirmed (MD-001, MD-002, MD-003).

The encouraging counterpoint is that most of these are configuration gaps, not architectural ones: the tenant is licensed for Entra ID P2, and the highest-impact fixes (admin MFA, all-users MFA, legacy-auth block, PIM eligibility) are low-to-medium effort and can be delivered within the first thirty days.

2. Scope & Methodology

The assessment was performed with the Entra ID Security & Endpoint Zero Trust Assessment toolkit (Get-EntraZTAssess), a read-only PowerShell solution that collects tenant configuration through Microsoft Graph and evaluates it against a declarative control library.

Approach

- **Read-only collection.** All Graph traffic is restricted to GET requests through a single validated wrapper. No write operations are possible and no tenant setting was changed.
- **Evidence-based scoring.** Each control is evaluated against persisted configuration snapshots, producing a finding with evidence, rationale and, where applicable, a recommended remediation and effort estimate.
- **Graceful degradation.** Where a licence, permission or data snapshot is missing, the control returns Not Assessed with the reason rather than a false Pass or Fail.

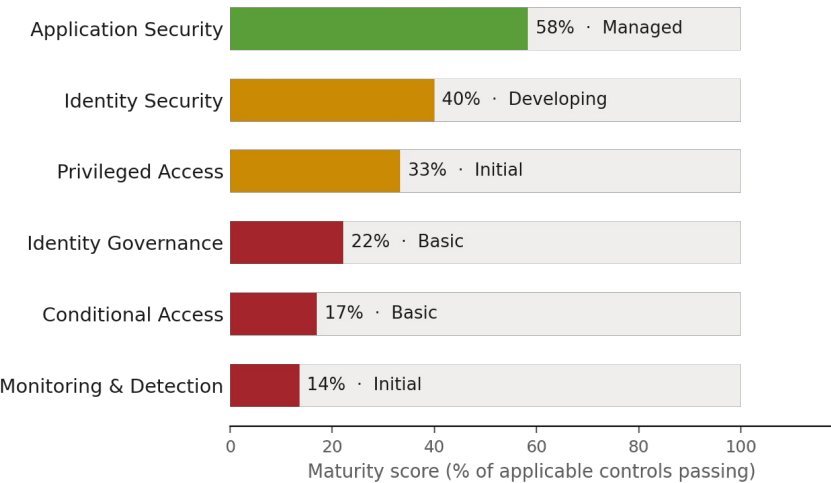
Rating scale

Rating	Meaning
Fail	The control is not met and represents an exploitable gap.
Partial	The capability exists but is incompletely deployed or adopted.
Pass	The control meets the expected Zero Trust standard.
Informational	No pass/fail judgement; a posture decision the client should confirm.
Not Assessed	Could not be evaluated (missing licence, permission or data).

Severity (Critical / High / Medium / Low) reflects the business risk of each Fail and drives the remediation order in Section 4. Remediation SLAs follow the toolkit defaults: Critical 7 days, High 30 days, Medium 90 days, Low 180 days.

3. Domain Maturity Scorecard

Each domain is scored as the proportion of applicable controls passing, and mapped to a maturity tier. Domains dependent on Intune or on-premises synchronisation returned insufficient data and are excluded from scoring (see Section 7).



Domain	Score	Tier	Summary
Application Security	58.3%	Managed	Strongest domain; one Critical app permission and a tail of dormant/unverified apps remain.
Identity Security	40%	Developing	Good passwordless choices undermined by low MFA registration and non-MFA-capable admins.
Privileged Access	33.3%	Initial	Entirely standing privilege; no PIM eligibility, too many Global Admins.
Identity Governance	22.2%	Basic	Entitlement management present, but no privileged-role reviews and open guest invitations.
Conditional Access	17%	Basic	Policy engine enforces almost nothing; key policies stuck in report-only.
Monitoring & Detection	13.6%	Initial	Risk signals collected but not enforced; retention unconfirmed.

4. Prioritised Remediation Roadmap

Open findings are sequenced below by severity and effort. The first wave targets the controls that close the largest exposure for the least effort — most are low or medium effort because the tenant is already licensed for the required capabilities.

Wave 1 — Critical (target ≤ 7 days)

ID	Action	Effort	Domain
ID-002	Register all privileged accounts for phishing-resistant MFA and enforce via Conditional Access on directory roles.	Low	Identity Security
CA-002	Enable a policy requiring phishing-resistant MFA for all administrator roles.	Low	Conditional Access
CA-001	Enable an all-users, all-apps MFA policy with documented break-glass exclusions.	Medium	Conditional Access
AS-002	Inventory and remove non-essential Tier-0 application permissions; protect the remainder.	Medium	Application Security

Wave 2 — High (target ≤ 30 days)

ID	Action	Effort	Domain
CA-003 / ID-003	Block legacy authentication for all users after confirming remaining usage.	Low–Med	Conditional Access
CA-011	Require MFA for Microsoft Azure Management (or adopt all-apps targeting).	Low	Conditional Access
PA-002	Convert standing privileged assignments to PIM-eligible with activation gates.	Medium	Privileged Access
PA-001	Reduce Global Administrators to a governed core of five or fewer.	Medium	Privileged Access
ID-001	Run an MFA registration campaign and enforce registration until ≥ 95%.	Medium	Identity Security
CA-004 / MD-001	Enforce sign-in and user risk through Conditional Access (P2 already licensed).	Medium	CA / Monitoring
CA-005	Require compliant/hybrid-joined devices for broad access, with app protection for BYOD.	High	Conditional Access
DT-001	Enrol/register unknown devices and require device signals in Conditional Access.	High	Device Trust

Wave 3 — Medium & Low (target ≤ 90 / 180 days)

ID	Action	Effort	Domain
PA-003	Require MFA + justification on Tier-0 PIM activation;	Low	Privileged Access

ID	Action	Effort	Domain
	add approval for GA.		
IG-001	Create recurring access reviews for privileged roles with auto-removal.	Low	Identity Governance
IG-005	Restrict guest invitations to admins; set guest access to restricted.	Low	Identity Governance
CA-012 / CA-013 / CA-006	Block device-code flow, require guest MFA, deploy session controls.	Low–Med	Conditional Access
MD-002 / MD-003	Triage risky users daily; export logs to a SIEM with IR-grade retention.	Low–Med	Monitoring
DT-004 / PA-010	Strengthen compliance policies; bind privileged use to compliant workstations.	Med–High	Device / Priv.
ID-007 / ID-008 / CA-009 / ID-012	Enable WHfB & TAP, retire stalled report-only policies, drive SSPR registration.	Low–Med	Identity

5. Detailed Technical Findings

Findings are grouped by domain and ordered by severity. Each entry records the evidence collected, why it matters, and — for every Fail and Partial — the recommended remediation, effort and authoritative Microsoft reference.

5.1 Identity Security (40% — Developing)

Authentication strength and credential posture for the wider user population. The tenant has a baseline of Conditional Access and has made good choices on passwordless and weak-method restrictions, but MFA registration is far below target and several privileged accounts cannot perform MFA at all.

ID-002 — Privileged accounts MFA capable **Fail** **Critical**

Evidence: 3 of 10 privileged users are not MFA capable. Sample:

sholly.ted@azimuthsolution.onmicrosoft.com, Julius.Oyekanmi@azimuthsolution.onmicrosoft.com, Chouaib@azimuthsolution.onmicrosoft.com.

Why it matters: A single privileged account without MFA provides a direct path to tenant compromise; coverage for administrators must be absolute.

Recommended remediation: Register all privileged accounts for phishing-resistant MFA immediately and enforce via a Conditional Access policy targeting directory roles. (effort: Low)

Reference: <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strengths>

ID-001 — MFA registration coverage **Fail** **High**

Evidence: 14 of 44 member users registered for MFA (31.8%). Threshold: 95%.

Why it matters: Accounts without MFA are the primary target of password spray and phishing; Microsoft telemetry shows MFA blocks the overwhelming majority of identity attacks.

Recommended remediation: Drive MFA registration campaigns and enforce registration via Conditional Access or an Identity Protection registration policy until coverage exceeds the threshold. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/authentication/howto-authentication-methods-activity>

ID-003 — Legacy authentication blocked **Fail** **High**

Evidence: No enabled Conditional Access policy blocks legacy authentication. Sign-in data unavailable; observation not assessed.

Why it matters: Legacy protocols cannot enforce MFA and are the most common vector for password spray; observed legacy sign-ins with no block escalate this to Critical.

Recommended remediation: Create a Conditional Access policy blocking legacy authentication clients for all users, after confirming remaining legacy usage owners and migration paths. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-block-legacy>

ID-007 — Windows Hello for Business configured **Fail** **Low**

Evidence: No enabled Windows Hello for Business enrolment configuration was found.

Why it matters: WHfB provides phishing-resistant, passwordless sign-in bound to device hardware, advancing both identity and device trust pillars.

Recommended remediation: Configure Windows Hello for Business via the tenant enrolment configuration or an Intune account protection policy. (effort: Medium)

Reference: <https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/>

ID-008 — Temporary Access Pass enabled Fail Low

Evidence: Temporary Access Pass is not enabled; passwordless onboarding requires a password-based first factor.

Why it matters: TAP enables first-run registration of passwordless credentials without a password ever existing, and provides a secure recovery path.

Recommended remediation: Enable Temporary Access Pass scoped to appropriate groups with conservative lifetime settings. (*effort: Low*)

Reference: <https://learn.microsoft.com/entra/identity/authentication/howto-authentication-temporary-access-pass>

ID-012 — Self-service password reset enabled Partial Medium

Evidence: SSPR enabled for 44 users but only 18.2% have registered; drive registration to make the capability effective.

Why it matters: SSPR reduces helpdesk-mediated resets, a social-engineering target, and pairs with combined registration for MFA.

Recommended remediation: Enable SSPR for all users with two methods required, using combined security information registration. (*effort: Low*)

Reference: <https://learn.microsoft.com/entra/identity/authentication/concept-sspr-howitworks>

ID-004 — Baseline protection in force Pass

Evidence: Baseline identity protection in force via Conditional Access (2 enabled policies).

Reference: <https://learn.microsoft.com/entra/fundamentals/security-defaults>

ID-005 — Weak telephony methods restricted Pass

Evidence: SMS and voice call authentication methods are disabled.

Reference: <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-methods>

ID-006 — FIDO2 / passkey enablement and adoption Pass

Evidence: FIDO2/passkey method is enabled. 1 user has registered a passkey or FIDO2 credential.

Reference: <https://learn.microsoft.com/entra/identity/authentication/howto-authentication-passwordless-passkeys>

ID-011 — Password expiry policy aligned to guidance Pass

Evidence: No verified domain enforces periodic password expiry, in line with current guidance.

Reference: <https://learn.microsoft.com/microsoft-365/admin/misc/password-policy-recommendations>

5.2 Conditional Access (17% — Basic)

Conditional Access is the policy engine that should enforce Zero Trust at every sign-in. Today it enforces almost nothing: there is no tenant-wide MFA, no admin MFA, no legacy-auth block, no device or risk conditions in enforced mode. Several well-intentioned policies remain stuck in report-only, giving a false sense of coverage.

CA-001 — MFA required for all users **Fail Critical**

Evidence: No enabled policy requires MFA for all users across all cloud apps.

Why it matters: Universal MFA enforcement is the single most effective identity control; report-only policies do not protect anyone.

Recommended remediation: Deploy an all-users, all-apps MFA policy with documented break-glass exclusions, moving from report-only to enabled after impact review. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-all-users-mfa>

CA-002 — Phishing-resistant MFA for administrators **Fail Critical**

Evidence: No enabled policy enforces MFA for administrator roles.

Why it matters: Administrator credentials are the highest-value target; they warrant stronger protection than the general user population.

Recommended remediation: Deploy a policy targeting directory roles requiring the phishing-resistant MFA authentication strength. (effort: Low)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-admin-mfa>

CA-003 — Legacy authentication block policy **Fail High**

Evidence: No enabled policy blocks legacy authentication clients.

Why it matters: This is the policy-side control underpinning ID-003; without it legacy protocols bypass every other Conditional Access control.

Recommended remediation: Create a block policy for Exchange ActiveSync and other legacy clients targeting all users. (effort: Low)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-block-legacy>

CA-004 — Risk-based access policies enforced **Fail High**

Evidence: No enabled risk-based Conditional Access policies were found despite Entra ID P2 licensing.

Why it matters: Risk-based policies respond automatically to credential leaks and anomalous sign-ins, shrinking the attacker window without user friction.

Recommended remediation: Create Conditional Access policies requiring MFA on medium-and-above sign-in risk and secure password change on high user risk. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-risk>

CA-005 — Device-based access controls **Fail High**

Evidence: No enabled policy requires a compliant or hybrid-joined device; unmanaged endpoints access corporate resources unchecked.

Why it matters: Device trust signals are central to Zero Trust; without device conditions, fully unmanaged endpoints access corporate data unchecked.

Recommended remediation: Deploy policies requiring compliant devices for broad access, with app protection policies as the BYOD alternative grant. (effort: High)

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-compliant-device>

CA-011 — Critical applications protected Fail High

Evidence: No enabled policy explicitly requires MFA for Microsoft Azure Management.

Why it matters: Azure management access grants control over infrastructure; per-app targeting frequently misses it when policies are not all-apps.

Recommended remediation: Ensure an enabled policy requires MFA for Microsoft Azure Management, or adopt all-apps targeting. *(effort: Low)*

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-policy-azure-management>

CA-006 — Session controls deployed Fail Medium

Evidence: No session controls (sign-in frequency, persistent browser restrictions) are deployed.

Why it matters: Session controls limit token replay value and reduce data persistence on unmanaged endpoints — key assume-breach mitigations.

Recommended remediation: Apply sign-in frequency to administrator sessions and never-persistent browser sessions on unmanaged devices. *(effort: Medium)*

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-conditional-access-session-lifetime>

CA-012 — High-risk authentication flows blocked Fail Medium

Evidence: Device code flow is not restricted; it remains available for token phishing.

Why it matters: Device code phishing is a prevalent real-world technique for stealing tokens without touching passwords or MFA.

Recommended remediation: Create a policy blocking device code flow except for audited exception groups that require it. *(effort: Low)*

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/concept-authentication-flows>

CA-013 — Guest access protected by MFA Fail Medium

Evidence: No enabled policy requires MFA for guest or external users.

Why it matters: Guests authenticate from tenants whose security posture is unknown; your policies are the only enforceable control.

Recommended remediation: Deploy a policy requiring MFA for all guest and external user types, with cross-tenant trust settings reviewed deliberately. *(effort: Low)*

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/howto-policy-guests-mfa>

CA-009 — Stalled report-only policies Fail Low

Evidence: Report-only policies older than 90 days: Block access for users with Insider Risk (Preview) ×2, MFA pilot – compromised user, Require MFA for Admin, Require MFA for all users.

Why it matters: Report-only policies enforce nothing; a stalled rollout signals an unprotected gap the organisation believes is closed.

Recommended remediation: Review report-only policy impact data and either enable or retire each stalled policy. *(effort: Low)*

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-report-only>

CA-007 — Named locations and trusted-location reliance Pass

Evidence: No MFA policy is bypassed by network location. Named locations defined: 0.

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/concept-assignment-network>

CA-008 — Policy exclusion hygiene Pass

Evidence: Exclusions are minimal: 0 excluded users (consistent with break-glass), no excluded groups.

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/plan-conditional-access>

CA-010 — Disabled policies closing current gaps **Pass**

Evidence: No disabled policies with meaningful controls were found.

Reference: <https://learn.microsoft.com/entra/identity/conditional-access/plan-conditional-access>

5.3 Privileged Access (33.3% — Initial)

How administrative power is granted, activated and contained. The tenant runs entirely on standing privilege — no PIM eligibility, too many Global Administrators, and weak activation gates on Tier-0 roles. Group-based and guest-based privilege paths are clean, which is a meaningful positive.

PA-001 — Global Administrator count within bounds **Fail** **High**

Evidence: 6 Global Administrator principals exceed the recommended maximum of 5.

Why it matters: Too few GAs risks lockout; too many multiplies the tenant-takeover attack surface beyond what governance can supervise.

Recommended remediation: Reduce Global Administrator membership to a governed core, delegating duties to least-privileged specific roles. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/role-based-access-control/best-practices>

PA-002 — Privileged access via PIM eligibility **Fail** **High**

Evidence: Permanent privileged assignments: 18; PIM-eligible: 0; permanent Global Administrators: 6.

Why it matters: Standing privilege is standing risk: permanently active roles are exploitable around the clock, while just-in-time activation shrinks the window to minutes.

Recommended remediation: Convert permanent privileged assignments to PIM-eligible with activation requirements, retaining only break-glass as permanent. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-configure>

PA-003 — PIM activation requirements for Tier-0 roles **Fail** **Medium**

Evidence: 3 of 8 Tier-0 roles lack MFA and/or justification on activation.

Why it matters: Activation gates ensure even a compromised eligible account cannot silently assume privilege.

Recommended remediation: Configure PIM role settings for Tier-0 roles to require MFA and justification, and add approval for Global Administrator activation. (effort: Low)

Reference: <https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-how-to-change-default-settings>

PA-010 — Privileged access bound to secured workstations **Fail** **Medium**

Evidence: No enabled policy binds privileged role usage to compliant or designated admin workstations.

Why it matters: Tier-0 credentials used from unmanaged endpoints inherit every piece of malware on those endpoints; device binding closes that path.

Recommended remediation: Introduce a policy requiring compliant (ideally PAW-filtered) devices for directory role activation and use. (effort: High)

Reference: <https://learn.microsoft.com/security/privileged-access-workstations/privileged-access-deployment>

PA-007 — Role-assignable group hygiene **Pass**

Evidence: No privileged roles are granted to groups.

Reference: <https://learn.microsoft.com/entra/identity/role-based-access-control/groups-concept>

PA-009 — Service principals with privileged access **Pass**

Evidence: No service principals hold privileged directory roles. GA-equivalent application permissions are assessed by the Applications module.

Reference: <https://learn.microsoft.com/entra/identity/role-based-access-control/best-practices>

5.4 Application Security (58.3% — Managed)

Governance of OAuth applications and workload identities — the tenant's strongest domain. Consent is well-restricted and credential hygiene is clean. The remaining gaps are a high-privilege app permission, plus a tail of dormant and unverified third-party service principals that should be pruned.

AS-002 — High-privilege application permissions **Fail** **Critical**

Evidence: Tier-0 application permissions held by workload identities: Microsoft Sample Data Packs — Directory.ReadWrite.All. High-risk grants: 5.

Why it matters: An app permission such as RoleManagement.ReadWrite.Directory is a standing path to Global Administrator that no MFA ever challenges.

Recommended remediation: Inventory every Tier-0 application permission, remove those not strictly required, and protect the remainder with credential hygiene and monitoring. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/enterprise-apps/grant-admin-consent>

AS-004 — Unused service principals with access **Fail** **Medium**

Evidence:

AS-007 — Ownerless app registrations **Pass**

Evidence: Every app registration holding credentials has at least one owner.

Reference: <https://learn.microsoft.com/entra/identity/enterprise-apps/overview-assign-app-owners>

5.5 Identity Governance (22.2% — Basic)

The lifecycle controls that keep access justified over time — access reviews, entitlement management and guest governance. Entitlement management is in use, but privileged-role recertification is absent and guest invitation settings are wide open.

IG-001 — Access reviews for privileged roles Fail Medium

Evidence: No access review covers privileged role assignments (2 review definitions exist).

Why it matters: Privilege accumulates silently; periodic recertification is the only scalable way to remove access that is no longer justified.

Recommended remediation: Create recurring access reviews for all privileged directory roles with auto-removal on non-response. (effort: Low)

Reference: <https://learn.microsoft.com/entra/id-governance/access-reviews-overview>

IG-005 — Guest invitation and permission settings Fail Medium

Evidence: Guest governance gaps: guest invitations are open to everyone (allowInvitesFrom = everyone).

Why it matters: Everyone-can-invite plus full guest directory read turns the tenant boundary into a suggestion.

Recommended remediation: Restrict guest invitations to admins and designated inviters, and set guest access to the restricted permission level. (effort: Low)

Reference: <https://learn.microsoft.com/entra/external-id/external-collaboration-settings-configure>

IG-006 — Cross-tenant access posture reviewed Informational

Evidence: Default cross-tenant access settings reviewed. Inbound trust: MFA = False, compliant device = False, hybrid joined = False. Confirm this trust posture is deliberate for every partner relationship.

Why it matters: Cross-tenant trust settings silently decide whether external MFA satisfies your Conditional Access; defaults deserve a deliberate decision.

Reference: <https://learn.microsoft.com/entra/external-id/cross-tenant-access-overview>

IG-003 — Entitlement management adoption Pass

Evidence: 2 entitlement management access packages in use.

Reference: <https://learn.microsoft.com/entra/id-governance/entitlement-management-overview>

5.6 Monitoring & Detection (13.6% — Initial)

Whether the tenant can see and respond to identity attacks. This is the lowest-scoring domain: risk signals are collected but not enforced, risky users linger unremediated, and log retention beyond 30 days is unconfirmed — bounding any future investigation.

MD-001 — Risk-based policies enforced **Fail** **High**

Evidence: No enabled Conditional Access policy enforces Identity Protection risk signals.

Why it matters: Risk detections that trigger no enforcement are a dashboard, not a control.

Recommended remediation: Enforce sign-in risk and user risk through Conditional Access policies (preferred over legacy Identity Protection policies). (effort: Medium)

Reference: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-configure-risk-policies>

MD-002 — Risky users remediated promptly **Fail** **Medium**

Evidence: 1 at-risk user unremediated beyond 7 days (0 high risk).

Why it matters: An unremediated high-risk user is a probably-compromised account that everyone has decided to ignore.

Recommended remediation: Triage risky users daily: remediate with secure password change or block, and automate via user-risk Conditional Access. (effort: Low)

Reference: <https://learn.microsoft.com/entra/id-protection/howto-identity-protection-remediate-unblock>

MD-003 — Audit log availability and retention **Partial** **Medium**

Evidence: Directory audit logs are available, but retention beyond the licence default (30 days) is not verifiable via Graph. Confirm diagnostic settings export audit and sign-in logs to long-term storage or a SIEM.

Why it matters: Incident response is bounded by log retention: default 30-day retention means any older intrusion is unreconstructable.

Recommended remediation: Export Entra ID audit and sign-in logs via diagnostic settings to Log Analytics, Sentinel, or storage with retention matching IR requirements. (effort: Medium)

Reference: <https://learn.microsoft.com/entra/identity/monitoring-health/howto-archive-logs-to-storage-account>

MD-006 — Sign-in and risk telemetry summary **Informational**

Evidence: Telemetry summary: legacy sign-in data unavailable; risk detection data unavailable.

Why it matters: The telemetry summary grounds the narrative findings in observed tenant activity.

Reference: <https://learn.microsoft.com/entra/id-protection/overview-identity-protection>

5.7 Device Trust *(Insufficient data)*

Endpoint trust signals that Conditional Access can consume. Most device checks could not run without an Intune licence and managed-device permissions, but directory-level data already shows a large unmanaged share and weak compliance policy content.

DT-001 — Unknown and unmanaged device exposure **Fail** **High**

Evidence: Classification of 11 devices: BYOD = 6, Unknown = 5. Unknown/unmanaged: 45.5% (threshold 20%).

Why it matters: Unmanaged endpoints carry no compliance signal and no endpoint protection; a large unmanaged share means Conditional Access device controls protect only part of the estate.

Recommended remediation: Enrol or register unknown devices, retire stale device objects, and require device signals through Conditional Access so unmanaged access is the exception. *(effort: High)*

Reference: <https://learn.microsoft.com/intune/intune-service/fundamentals/deployment-guide-enrollment>

DT-004 — Compliance policy quality per platform **Fail** **Medium**

Evidence: Every compliance policy has weak control coverage: Android (0 control signals).

Why it matters: A compliance policy that checks nothing meaningful grants the compliant-device signal without verifying device health.

Recommended remediation: Strengthen compliance policies to require encryption, minimum OS versions, password/PIN, and jailbreak/root blocking per platform. *(effort: Medium)*

Reference: <https://learn.microsoft.com/intune/intune-service/protect/device-compliance-get-started>

6. Strengths to Preserve

Fourteen controls passed. These represent good decisions already made and should be protected against regression as the remediation programme proceeds.

- User consent is restricted to Microsoft's recommended policy, and application credential hygiene is clean — no long-lived secrets, no secrets on privileged apps (AS-001, AS-003).
- Phishing-resistant passwordless authentication is enabled (FIDO2/passkeys), weak telephony methods (SMS, voice) are disabled, and password expiry has correctly been dropped in line with current guidance (ID-005, ID-006, ID-011).
- Conditional Access exclusions and network-location bypasses are minimal, avoiding the silent gaps attackers hunt for (CA-007, CA-008, CA-010).
- No privileged roles are granted to ordinary groups and no service principals hold privileged directory roles, closing two common privilege-escalation paths (PA-007, PA-009).
- Entitlement management is already in use for governed, time-bound access packages (IG-003).

7. Coverage Gaps (Not Assessed)

Forty-six controls could not be evaluated. None indicates a problem with the tenant in itself; each reflects a data input the assessment did not have. They fall into three groups:

- **Intune / managed-device dependent (~ 38 controls).** Endpoint management, corporate and BYOD device governance, and most device-trust detail require an Intune licence and the DeviceManagementManagedDevices.Read.All permission. Granting read access and re-running the Devices module would close this gap.
- **Not applicable — cloud-only tenant (7 controls).** Hybrid Identity and Defender for Identity checks assume on-premises directory synchronisation and domain controllers, which this tenant does not have. These are correctly out of scope.
- **Requires combined modules or beta data (remaining controls).**